

Demonstration of RFC 8705

- Cryptographic proof of possession of agent authentication token
- Agent requests token, certificate generated, successful authentication
- Adversary agent is in possession of the legitimate token strong, fails to authenticate two ways
- Jason Soroko, Senior Fellow, Sectigo

DEMO 3

RFC 8705 mTLS certificate-bound token

Token bound

Original certificate client

Token bound to cert

Issue via mTLS

Use with same cert

Copy token

Certificate thumbprint

SLHgVbZNoGIS0I3XILZSMHGsgyyeJbZc1zKKQ3qJv3c

Certificate-bound token

y5y3nBdCfCf5f0z2f7nrlsImK5C6C0kPkvXvC37.ey3p3e3mRf5f0c7vZdG5v4vV5KZXBvC7KZVWfVlWfVfXVKJf0B5J7fVvWZGv
 tby1hcGkiLCJzdWliOiJtdGxzLWRlbW8tY2xpZW50liwic2NvcGUiOiJyZWfkOnRyZWZzdXJ5liwiaWF0ljoXNzgWnJg0
 NTg1LCJleHAiOiE3ODA2ODUxODUsInRva2VuX3R5cGUiOiJCZWYyX2liLCJibmYiOnsieDV0I1MyNTYiOiJTTEhnV
 mJmTm9HSVNPSTNYSUxaU0I1R3NHX2I1SmJaYzF6S0tRM3FkdjNvIn19.d0as5E8icjUmW89GcidjcosVKJ5sGEP6rS
 zNknekAQ

Copied-token client

Waiting

Try with different cert

Try with no cert

Different valid cert

none

Copied token

```
{
  "title": "RFC 8705 token issued over mTLS",
  "http_status": 200,
  "ok": true,
  "www_authenticate": null,
  "response": {
    "ok": true,
    "token_type": "Bearer",
    "access token":
```

Legitimate and successful cert
issuance and mTLS handoff of token to
agent

DEMO 3

RFC 8705 mTLS certificate-bound token

Holder works

Original certificate client

Access granted

Issue via mTLS

Use with same cert

Copy token

Certificate thumbprint

SLHqVbZNoGISOI3XILZSMHGSGyyeJbZc1zKKQ3qJv3o

Certificate-bound token

y5nBdGcCi05tZf7nHsImK5Ccc0kPxcV37:ey3p3c1w050c1v2dG5v4w5KEXbvcCTKZVv7vIwH7XVKj0bG7j7vVwZGv
 tby1hcGkiLCJzdWliOiJtdGxzLWRlbW8tY2xpZW50Iiwic2NvcGUiOiJyZWfkOnRyZWZzdXJ5IiwiaWF0IjoxNzgwNjg0
 NTg1LCJleHAiOiE3ODA2ODUxODUsInRva2VuX3R5cGUiOiJCZWYyX2liLCJibmYiOnsieDV0I1MyNTYiOiJTTEhnV
 mJaTm9H5QVNPSTNYSUxaU01IR3NHeXII5mJaYzF6S0tRM3FKdjNvIn19.do8as5E8icjUmW89GcidjcosVKJSsGEP6rS
 zNkNeAtAQ

Copied-token client

Waiting

Try with different cert

Try with no cert

Different valid cert

none

Copied token

```
{
  "title": "mTLS holder request",
  "http_status": 200,
  "ok": true,
  "www_authenticate": null,
  "response": {
    "ok": true,
    "mode": "rfc8705-mtls",
    "account": "Northwind Treasury"
```

Legitimate and successful authentication between agent and MCP

Certificate-bound token

```
eysmbGdOisfoZnNhsimkScCioikpXvCs7.eyspcSiMlOiSocnvZdGsvdVwSKLXBvCCrKZWfVilWHTXVKijoiBG7jFvwWzGv  
tby1hcGkiLCJzdWliOiJtdGxzLWRlbW8tY2xpZW50Iiwic2NvcGUiOiJyZWFrOnRyZWZzdXJ5IiwiaWF0IjoxNzgwNjg0  
NTg1LCJleHAiOiE3ODA2ODUxODUsInRva2VuX3R5cGUiOiJCZWZyZXliLCJjbmYiOmsieDV0I1MyNTYiOiJTTEhnV  
mJaTm9HSVNPNSTNYSUxaU01IR3NHExIIsmJaYzF6S0tRM3FKdjNvln19.do8as5E8icjUmW89GcidjcosVKJSsGEP6rS  
zNknekAQ
```

Copied-token client Copy rejected

Try with different cert

Try with no cert

Different valid cert KXYASjEBIZkMATxpCsN6t0jIj0k-MMzkK5_aia-lKsY

Copied token

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJ0cnVzdGJvdW5kLXBvcC1kZW1vliwiYXVkljoibG9jYWwtZGVtby1hcGkiLCJzdWliOiJtdGxzLWRLbW8tY2xpZW50Iiwic2NvcGUiOiJyZWFrOnRyZWZzdXJ5IiwiaWF0IjoxNzgWnJg0NTg1LCJleHAiOiJlE3ODA2ODUxODUxInRva2VuX3R5cGUiOiJlE3ZWZyZXliLCJlbmYiOiJlE3DV0I1MyNTYiOiJlE3TTEhNvbmJaTm9HSVNPSTNYSUxaU01IR3NHeXlIImJaYzF6S0tRM3FKdjNvIn19.do8as5E8icjUmW89GcidjcosVKJSsGEP6rSzNknokAQ

```
{
  "title": "mTLS copied-token request with different cert",
  "http_status": 401,
  "ok": false,
  "www_authenticate": null,
  "response": {
    "ok": false,
    "error": "invalid_token",
    "message": "Invalid mTLS certificate binding: current client certificate"
  }
}
```

Adversary possesses token, tries and fails to authenticate to MCP with self signed cert

RFC 8705 mTLS certificate-bound token

Original certificate client

Access granted

Issue via mTLS

Use with same cert

Copy token

Certificate thumbprint

SLHgVbZNoGISOI3XILZSMHGsGyyeJbZc1zKKQ3qJv3o

Certificate-bound token

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJ0cnVzdGJvdW5kLXBvcC1kZW1vliwiYXVkljoibG9jYWwtZGVtby1hcGkiLCJzdWliOiJtdGxzLWRLbW8tY2xpZW50Iiwic2NvcGUiOiJyZWFKOnRyZWZkdXJ5liwiaWF0IjoxNzgwNjg0NTg1LCJleHAiOiJlE3ODA2ODUxODUsluRva2VuX3R5cGUiOiJCZWZyZXliLCJibmYiOnsieDV0I1MyNTYiOiJTTEhnVmJaTm9HSVNPSTNYSUxaU01IR3NHeXlSmJaYzF6S0tRM3FKdjNvIn19.do8as5E8icjUmW89GcidjcosVKJSsGEP6rSznknekAQ

Copied-token client

Copy rejected

Try with different cert

Try with no cert

Different valid cert

KXYASjEBIZkMATxpCsN6t0jIj0k-MMzkK5_aia-lkSy

Copied token

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJ0cnVzdGJvdW5kLXBvcC1kZW1vliwiYXVkljoibG9jYWwtZGVtby1hcGkiLCJzdWliOiJtdGxzLWRLbW8tY2xpZW50Iiwic2NvcGUiOiJyZWFKOnRyZWZkdXJ5liwiaWF0IjoxNzgwNjg0NTg1LCJleHAiOiJlE3ODA2ODUxODUsluRva2VuX3R5cGUiOiJCZWZyZXliLCJibmYiOnsieDV0I1MyNTYiOiJTTEhnVmJaTm9HSVNPSTNYSUxaU01IR3NHeXlSmJaYzF6S0tRM3FKdjNvIn19.do8as5E8icjUmW89GcidjcosVKJSsGEP6rSznknekAQ

```
{
  "title": "mTLS copied-token request with no cert",
  "http_status": 502,
  "ok": false,
  "www_authenticate": null,
  "response": {
    "ok": false,
    "error": "mtls_request_failed",
    "message": "TLS handshake failed because no client certificate was presented.",
  }
}
```

Adversary possesses token, tries and fails to authenticate to MCP, without a cert and mTLS session